

🚀 Project Overview

This repository contains a foundational Governance, Risk, and Compliance (GRC) Risk Register developed for **Apex IT Services**, a simulated small-to-medium IT consultancy and managed services provider. The primary objective of this project is to demonstrate a structured approach to identifying, assessing, and mitigating operational and cyber risks in an enterprise environment.

The scenario focuses on core service offerings including database management, endpoint security, and the deployment of Managed Security Awareness Training (MSAT) for clients.

🎯 Key Objectives

- * **Risk Identification:** Catalog critical threats spanning cybersecurity, application security, third-party vendor management, IT operations, and regulatory compliance.
- * **Control Assessment:** Evaluate existing security controls against inherent risk levels.
- * **Treatment Strategy:** Formulate actionable mitigation plans to reduce residual risk to an acceptable threshold, leveraging industry-standard frameworks (e.g., NIST CSF).
- * **Strategic Alignment:** Illustrate the transition from a static risk document to a dynamic, continuously audited GRC lifecycle.

📁 Repository Contents

- * **Apex_IT_GRC_Risk_Register.xlsx**: The core workbook containing:
 - * **Risk Register:** A detailed ledger of identified threats, including Client Phishing, SQL Injections, Supply Chain Breaches, and Unpatched Systems.
 - * **Dashboard:** A high-level executive summary tracking inherent versus residual risk levels across Critical, High, Medium, and Low tiers.
- * **Apex IT.docx**: The foundational project charter and conceptual summary outlining the methodology and company profile.

🧩 Core Concepts & Methodologies Highlighted

- * **Cybersecurity & Awareness:** Implementing automated MSAT programs to mitigate human-element vulnerabilities (e.g., credential harvesting).
- * **Application & Database Security:** Utilizing Web Application Firewalls (WAF), parameterized SQL queries, and DevSecOps vulnerability scanning to prevent injection attacks.
- * **Third-Party Risk Management (TPRM):** Evaluating vendor supply chains and enforcing SOC 2 Type II compliance requirements.
- * **IT Operations:** Transitioning from manual patch cycles to automated workflows integrated with AI-driven Intrusion Detection Systems (IDS).
- * **Compliance & Data Privacy:** Mapping data flows to compliance frameworks and enforcing data-at-rest encryption for PII.

💡 Key Takeaway

A static risk register is only the first step in a mature security posture. The true value of this GRC initiative lies in the actionable treatment plans—such as deploying MSAT and automating patch management—and how these controls are continuously audited and updated as the threat landscape evolves.

This project was developed to showcase practical skills in IT Governance, Risk Management, Database Security, and Cybersecurity Operations.